CONFIDENCIAL - SUJEITO AO ACORDO DE CONFIDENCIALIDADE ASSINADO EM 09/11/2026

PACOTE DE DUE DILIGENCE DE SEGURANÇA

Nexaflow ERP - Bloco 2

Documentação complementar ao questionário de segurança da informação enviado pela CloudFlux

Campo	Informação
Fornecedor	Nexaflow Sistemas Ltda. - CNPJ 12.345.678/0001-90
Cliente solicitante	CloudFlux
Responsável comercial	Rafael Souza - Executivo de Contas Sênior
Data de emissão	09/11/2026
Bloco	2 de 2 (documentos disponibilizados mediante NDA).

Índice

Doc.	Documento	Referência no questionário
1	Plano de Continuidade de Negócios e Recuperação de Desastres (BCP/DR)	Domínio 5 - Continuidade / DR (itens 1 e 2)
2	Procedimento de Resposta a Incidentes de Segurança	Domínio 6 - Gestão de Incidentes (itens 1 e 2)
3	Controle de Acesso Interno: extrato da política e relatório de aderência ao MFA	Domínio 2 - Gestão de Acesso

Os documentos deste bloco são confidenciais e foram disponibilizados à CloudFlux exclusivamente para a finalidade de avaliação de segurança, nos termos do Acordo de Confidencialidade assinado em 09/11/2026.

DOCUMENTO 1

Plano de Continuidade de Negócios e Recuperação de Desastres (BCP/DR)

Código: NX-CON-PLA-002 | Versão 4.1 | Última revisão do documento: 02/2026 | Aprovação: Comitê de Continuidade

1. Objetivo e escopo

Estabelecer as diretrizes para a continuidade dos serviços do Nexaflow ERP e a recuperação do ambiente de produção em caso de interrupção grave. O plano cobre o ambiente de produção do produto, hospedado na AWS (região São Paulo), e os serviços de apoio necessários à sua operação.

2. Objetivos de recuperação

Indicador	Valor declarado	Descrição
RTO	4 horas	Tempo máximo para restabelecer os serviços após a declaração do desastre.
RPO	1 hora	Janela máxima de perda de dados tolerada.

3. Estratégia de recuperação

Replicação do banco de dados entre zonas de disponibilidade, backups automáticos com retenção de 30 dias e infraestrutura provisionada como código, permitindo a reconstrução do ambiente a partir de modelos versionados.

4. Papéis e responsabilidades

Papel	Responsabilidade
Comitê de Continuidade	Declarar o desastre, aprovar o plano e acompanhar os resultados dos testes.
Equipe de Infraestrutura	Executar os procedimentos técnicos de recuperação.
Gerente de Segurança da Informação	Assegurar a aplicação dos controles de segurança durante a recuperação.
Comercial / Suporte	Comunicar clientes durante o evento.

5. Testes do plano

Os testes de recuperação são conduzidos conforme o cronograma definido pelo Comitê de Continuidade, e seus resultados são registrados e apresentados ao Comitê.

Histórico de testes formais de recuperação

Data	Tipo	Resultado	RTO medido
05/2025	Recuperação completa do ambiente de produção em ambiente isolado	Concluído, com plano de ação para ajustes de documentação	3h40

DOCUMENTO 2

Procedimento de Resposta a Incidentes de Segurança

Código: NX-SEG-PRO-021 | Versão 3.2 | Última revisão: 01/2026

1. Objetivo

Definir o fluxo de identificação, classificação, contenção, comunicação e tratamento de incidentes de segurança que afetem o Nexaflow ERP e os dados dos clientes.

2. Classificação de severidade

Nível	Critério	Exemplo
Crítico	Comprometimento confirmado de dados de clientes ou indisponibilidade generalizada	Acesso não autorizado a base de dados de produção
Alto	Risco relevante, sem confirmação de comprometimento de dados	Credencial administrativa exposta
Médio	Evento com impacto limitado e contido	Tentativa de intrusão bloqueada
Baixo	Evento sem impacto no serviço	Varredura automatizada de portas

3. Etapas

Etapa	Atividade	Responsável
1. Detecção e registro	Registro do evento a partir de monitoramento, alerta ou relato	Operações / Suporte
2. Triagem e classificação	Análise inicial e definição da severidade	Gerente de Segurança da Informação
3. Contenção	Isolamento e medidas para limitar o impacto	Infraestrutura
4. Investigação	Análise de causa e do alcance do incidente	Segurança da Informação
5. Comunicação	Comunicação aos clientes afetados e, quando aplicável, ao encarregado (DPO)	Comercial / DPO
6. Recuperação e lições aprendidas	Restabelecimento do serviço e registro das ações corretivas	Diretoria de Tecnologia

4. Comunicação ao cliente

A Nexaflow comunicará os clientes afetados **em até 5 (cinco) dias úteis** após a confirmação do incidente, prazo que corresponde ao SLA contratual padrão. Para incidentes classificados como críticos, será realizada comunicação preliminar sempre que viável, com as informações disponíveis no momento.

5. Atuação de terceiros

O atendimento de suporte técnico de segundo nível é prestado por parceiro contratado, que poderá ser acionado durante a investigação para apoio no diagnóstico, conforme chamado registrado.

DOCUMENTO 3

Controle de Acesso Interno: Extrato da Política e Relatório de Aderência ao MFA

Parte A - Extrato da Política de Controle de Acesso

Código: NX-SEG-POL-005 | Versão 5.0 | Última revisão: 03/2026

3.2 Autenticação. O acesso a sistemas corporativos, repositórios de código, esteiras de integração e entrega, rede privada virtual e ambientes de nuvem exige autenticação multifator, conforme o Procedimento NX-SEG-PRO-009.

3.4 Privilégio mínimo. Os acessos são concedidos conforme a função e revisados semestralmente pelos gestores, com registro das revisões.

3.6 Acessos privilegiados. Contas administrativas de produção utilizam chave de segurança física e têm as sessões registradas.

Parte B - Relatório de aderência ao MFA

Data-base: 31/10/2026 | Fonte: diretório corporativo da Unidade de Desenvolvimento (Campinas/SP)

Grupo	Usuários ativos	Com MFA ativo	Aderência
Desenvolvimento	118	118	100%
Qualidade e testes	22	22	100%
Infraestrutura e administradores (chave FIDO2)	14	14	100%
Total	**154**	**154**	**100%**

Relatório gerado pela área de Tecnologia da Informação e validado pelo Gerente de Segurança da Informação.

Arquivo fictício produzido exclusivamente para fins de simulação do Projeto 10 (GRC - Gestão de Risco de Terceiros). Nexaflow Sistemas Ltda., seus colaboradores, documentos e certificações são fictícios e não representam nenhuma empresa real.